

Chapter 6: Credentials in Network Shares

1 The Concept: Exposed Network Shares



Technical Concept: Unsecured Credentials in the Wild

Network shares are among the most frequently encountered misconfigurations in Active Directory. Attackers often find unencrypted credentials and tokens scattered throughout shared scripts and configuration files.

- **Why Shares Become Open:** Admins may lock access down initially but eventually open it to "Everyone" or "Users" (which includes all Domain Users).
- **Misplaced Scripts:** Admins often test scripts in local folders on the C:\ drive, unaware that those folders have been shared with the network.
- **Temporary Shares:** Shares created to move data to a server are often forgotten and left open indefinitely.



The Grand Hotel Analogy: The Shared Storage Cabinets

Imagine the hotel has various **Storage Cabinets** (*Network Shares*) located in the **Loading Dock** area.

- **The Open Door:** A cabinet meant for the **Accounting Team** (*Admins*) is accidentally left unlocked, allowing any **Dishwasher** (*Domain User*) to peek inside.
- **The Hidden Cabinet (dev\$):** The manager puts a cabinet behind a curtain (*Hidden Share*) and assumes no one will see it. However, a thief with a flashlight (*Security Tool*) finds it immediately.
- **The Note:** Inside one of these cabinets, a lazy staff member has left a clipboard (*Configuration File*) with the master password for the **Front Desk Computers** written on it.

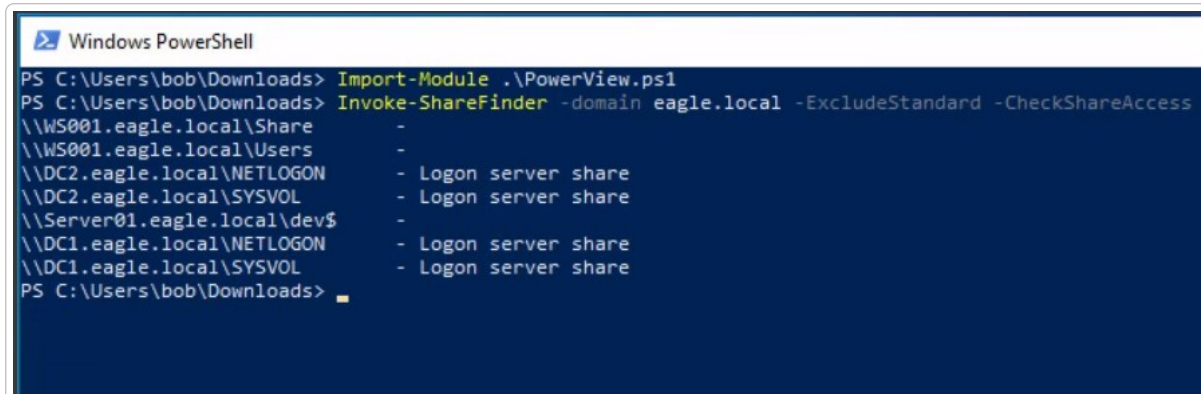
2 Attack Execution: Step-by-Step

2.1 Step 1: Enumerating Network Shares

We use **PowerView** to identify every share in the domain that our current user (**Bob**) has at least read access to.

>_ Terminal: Windows PowerShell (as bob)

```
Invoke-ShareFinder -domain eagle.local -ExcludeStandard -CheckShareAccess
```



```
Windows PowerShell
PS C:\Users\bob\Downloads> Import-Module .\PowerView.ps1
PS C:\Users\bob\Downloads> Invoke-ShareFinder -domain eagle.local -ExcludeStandard -CheckShareAccess
\\WS001.eagle.local\Share -
\\WS001.eagle.local\Users -
\\DC2.eagle.local\NETLOGON - Logon server share
\\DC2.eagle.local\SYSVOL - Logon server share
\\Server01.eagle.local\dev$ -
\\DC1.eagle.local\NETLOGON - Logon server share
\\DC1.eagle.local\SYSVOL - Logon server share
PS C:\Users\bob\Downloads>
```

The `Invoke-ShareFinder` command is used to identify accessible network shares across the domain.

- **Normal/Standard Shares:** The output shows standard shares such as `NETLOGON` and `SYSVOL` on Domain Controllers (`DC1` and `DC2`). These are required for domain operations like logon scripts and Group Policy data.
- **The "dev\$" Share:** The path `\\Server01.eagle.local\dev$` is particularly interesting because of the dollar sign (\$) at the end of its name.
- **Hidden Nature:** In Windows, shares ending with a \$ are "hidden" from standard browsing tools like Windows Explorer.
- **Misconception of Security:** Administrators often mistakenly believe that hidden shares are secure because users cannot see them without knowing the exact path. However, security tools like `Invoke-ShareFinder` easily list them, often revealing sensitive development or backup data that was not properly secured.

2.1.1 Identifying "Interesting" Share Patterns

Beyond hidden shares, attackers look for specific patterns that suggest high-value data:

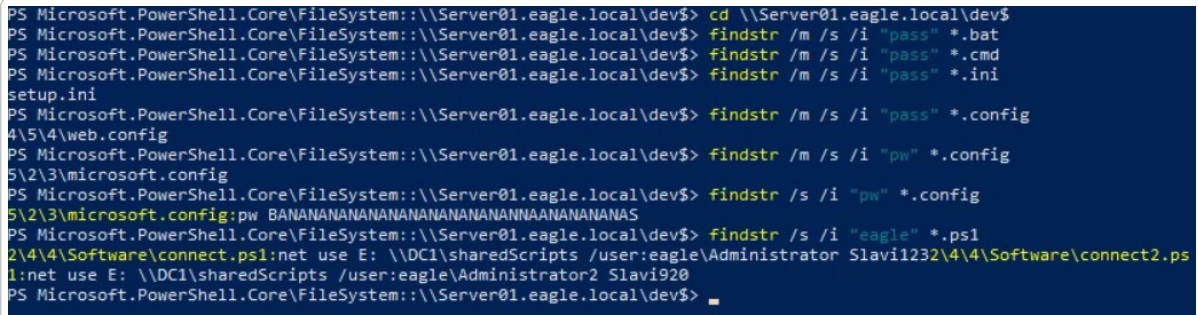
- **Administrative Shares:** Shares like `C$` or `ADMIN$` (which are also hidden) provide full access to a remote system's drive if the user has local administrative privileges.
- **Departmental/Project Shares:** Names like `HR`, `Finance`, `Backups`, or `Dev` often contain files with sensitive information or configuration data.
- **Common Script Folders:** Folders named `Scripts` or `Deploy` often house batch files or PowerShell scripts that might contain hardcoded credentials.

2.2 Step 2: Hunting for Credentials (*findstr*)

Once we identify a suspicious share like `dev$`, we search its contents for keywords like "pass," "pw," or the domain name.

```
>_ Terminal: Windows PowerShell (Searching for 'pass')

cd \\Server01.eagle.local\dev$
findstr /m /s /i "pass" *.bat *.ini *.config
```



```
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ cd \\Server01.eagle.local\dev$
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ findstr /m /s /i "pass" *.bat
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ findstr /m /s /i "pass" *.cmd
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ findstr /m /s /i "pass" *.ini
setup.ini
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ findstr /m /s /i "pass" *.config
4\5\4\web.config
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ findstr /m /s /i "pw" *.config
5\2\3\microsoft.config
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ findstr /s /i "pw" *.config
5\2\3\microsoft.config:pw BANANANANANANANANANANANANANANANANANANANANANANANAS
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$ findstr /s /i "eagle" *.ps1
2\4\4\Software\connect.ps1:net use E: \\DC1\sharedScripts /user:eagle\Administrator Slavi1232\4\4\Software\connect2.ps
1:net use E: \\DC1\sharedScripts /user:eagle\Administrator2 Slavi920
PS Microsoft.PowerShell.Core\FileSystem: \\Server01.eagle.local\dev$
```

This image displays a series of manual enumeration steps on a network share (`\\Server01.eagle.local\dev$`) using the `findstr` command to locate sensitive information.

- **Initial Keyword Search ("pass"):** The user searched across various file types (`.bat`, `.cmd`, `.ini`, `.config`) for the string "pass".
- **Discovery:** This led to the identification of two sensitive files: `setup.ini` and `web.config`.
- **Targeted Search ("pw"):** A search for "pw" was used to find specific lines of code containing passwords.
- **Discovery:** The tool identified `microsoft.config`, which contained a clearly visible password string: `BANANANANANANANANANANANANANANANANANANANANANANANAS`.
- **Domain-Specific Search ("eagle"):** The user searched for the NetBIOS name of the domain, as common administrative commands (like `net use`) often include domain credentials.
- **Credential Leak:** This search was highly successful, revealing plaintext credentials in two different PowerShell scripts (`connect.ps1` and `connect2.ps1`):
 - **Administrator:** Password discovered as `Slavi123`.
 - **Administrator2:** Password discovered as `Slavi920`.

3 Detection & Prevention



Technical Concept: Defense Strategies

- **Prevention (Least Privilege):** Lock down shares so that "Everyone" or "Domain Users" do not have access by default.
- **Detection (Behavioral):** Alert on "One-to-Many" connections; it is abnormal for a workstation to connect to hundreds of other devices simultaneously, as *Invoke-ShareFinder* does.
- **Honeypots:** Leave a realistic script in a share containing a **fake password** for a service account. Any failed logon attempt (Event ID 4625) using that password is a high-fidelity indicator of a breach.